

Information Security Compliance Policy & Standard

Compliance Gap Analyzer — Structured Ground Truth for RAG & Automated Auditing

Document ID: ORG-SEC-GAP-2026

Reference Framework: ISO/IEC
27001:2022 (Annex A)

Classification: Internal / Automated
Ingestion

Domain 1: Identity & Access Management (IAM)

SEC-ISO-8.5: Secure Authentication (MFA Enforcement)

ISO 27001 CLAUSE A.8.5

SEVERITY: CRITICAL

Control Requirements:

- Multi-Factor Authentication (MFA) must be enforced for all external remote access connections (VPN, ZTNA, PAM gateways) by employees and third parties.
- MFA enforcement is mandatory across all cloud infrastructure consoles (AWS, Azure, GCP), management interfaces, and core production systems.
- Authentication mechanisms must use dedicated authenticator apps (TOTP/Push notifications) or hardware security keys (FIDO2/WebAuthn). SMS-based OTP is prohibited for privileged access.

Quantitative Verification Criteria for Agent:

- MFA Remote Access Coverage = 100%
- MFA Privileged / Admin Access Coverage = 100%
- Allowed Authentication Methods = App / FIDO2 Key (value SMS is classified as Partially Compliant)

SEC-ISO-8.2: Privileged Access Rights & Access Review

ISO 27001 CLAUSE A.8.2 / A.5.15

SEVERITY: HIGH

Control Requirements:

- Allocation of administrative privileges must follow the principle of Least Privilege (PoLP) and requires formal documented approval.
- A periodic access review must be conducted at least once every 90 days. Inactive or dormant accounts (unused for ≥ 60 days) must be automatically disabled or revoked.

Quantitative Verification Criteria for Agent:

- Access Review Frequency: ≤ 90 days
- Inactive Account Auto-Disable Threshold: ≤ 60 days

Domain 2: Vulnerability Management & Hardening

SEC-ISO-8.8: Technical Vulnerability Management & Patch SLA

ISO 27001 CLAUSE A.8.8

SEVERITY: CRITICAL

Control Requirements:

1. Automated infrastructure and application vulnerability scans must be executed across all organizational digital assets at least every 30 days.
2. Patch remediation service level agreements (SLAs):
 - Critical severity (CVSS 9.0–10.0 or Known Exploited Vulnerabilities): remediation required within **7 business days** of disclosure.
 - High severity (CVSS 7.0–8.9): remediation required within **30 business days**.
3. Where vendor patching is infeasible, compensating controls (e.g., WAF rules, network ACL isolation) must be implemented and documented within 48 hours.

Quantitative Verification Criteria for Agent:

- Automated Scan Cadence: `≤ 30 days`
- Remediation SLA (Critical): `≤ 7 days` | Remediation SLA (High): `≤ 30 days`

SEC-ISO-8.9: Configuration Management & System Hardening

ISO 27001 CLAUSE A.8.9

SEVERITY: MEDIUM

Control Requirements:

1. All servers, operating systems, network appliances, and container runtime environments must be hardened according to recognized industry baselines (e.g., CIS Benchmarks).
2. All default accounts, insecure protocols, unused network ports, and vendor-preset default passwords must be disabled or removed prior to production deployment.

Quantitative Verification Criteria for Agent:

- Hardening Baseline Documented & Enforced: `True`
- Active Default Accounts / Passwords: `0`

Domain 3: Network Security & Data In-Transit

SEC-ISO-8.22: Network Segregation & Isolation

ISO 27001 CLAUSE A.8.22

SEVERITY: HIGH

Control Requirements:

1. Strict logical or physical network segregation must be enforced between Production, Staging, and Development environments.
2. Direct inbound communication from the public Internet to internal database layers is strictly forbidden; all traffic must traverse an application proxy/WAF inside a DMZ.

Quantitative Verification Criteria for Agent:

- Environment Segregation (Prod/Dev): `Implemented & Isolated`
- Direct Internet Inbound to Database: `False`

SEC-ISO-8.24: Cryptographic Controls & Transit Encryption

ISO 27001 CLAUSE A.8.24

SEVERITY: HIGH

Control Requirements:

1. All sensitive organizational data in transit across internal and external networks must be encrypted using TLS 1.2 or higher (TLS 1.3 recommended).
2. Cleartext communication protocols (Telnet, FTP, unencrypted HTTP) are strictly prohibited.
3. Data-at-rest in databases and cloud object storage must be encrypted using industry-standard cryptography (AES-256 or equivalent).

Quantitative Verification Criteria for Agent:

- Minimum TLS Protocol Version: TLS 1.2
- Active Cleartext Protocols: 0
- Database / Storage Encryption at Rest: True (AES-256)

Domain 4: Logging, Auditing & ICT Resilience

SEC-ISO-8.15: Audit Logging & Monitoring

ISO 27001 CLAUSE A.8.15

SEVERITY: MEDIUM

Control Requirements:

1. Audit logs covering user authentication, privilege escalation, and critical system events must be ingested into a central SIEM/log aggregation platform in real time.
2. Log retention period must be at least 365 days, with at least 90 days immediately searchable (hot/warm storage).

Quantitative Verification Criteria for Agent:

- Central SIEM Ingestion Enabled: True
- Total Log Retention Period: ≥ 365 days

SEC-ISO-5.30: ICT Readiness for Business Continuity & Backups

ISO 27001 CLAUSE A.5.30

SEVERITY: CRITICAL

Control Requirements:

1. Core organizational systems and business data must undergo automated backup cycles at least once every 24 hours.
2. At least one secondary backup copy must be immutable (Write-Once-Read-Many / WORM) or logically air-gapped against ransomware encryption.
3. Full recovery restore drills must be performed and validated at least semi-annually (every 180 days).

Quantitative Verification Criteria for Agent:

- Backup Frequency: ≤ 24 hours
- Immutable / Air-Gapped Copy Active: True
- Restore Drill Validation Cadence: ≤ 180 days

RAG Ingestion & Indexing Best Practices (ChromaDB / FAISS):

- **Chunk Granularity:** Index each control card (`SEC-ISO-X.X`) as an independent document chunk.
- **Metadata Schema:** Store `control_id`, `domain`, `severity`, and `standard_clause` as queryable metadata attributes.
- **Hallucination Defense Prompt:** Instruct the LLM evaluator: *"Evaluate the system status strictly against the quantitative Verification Criteria. If any required metric is absent in the input table, flag as 'Missing Data / Gap' rather than inferring compliance."*